

Vulnerability Analysis — Study Notes

CEHv13 • Module 05 | Prepared by Dhruva | July 20, 2026

1. Core Concepts

Vulnerability — a weakness in a system, design, implementation, or control that can be exploited to violate its security policy.

Vulnerability Analysis / Assessment — the systematic process of identifying, quantifying, and prioritizing (ranking) vulnerabilities in a system. It does **not** exploit the vulnerability (that's penetration testing) — it only discovers and reports it.

Types of Vulnerability Assessment

Type	Description
Active Assessment	Sends traffic/probes directly to the target (e.g., OpenVAS, Nessus)
Passive Assessment	Sniffs traffic without interacting with the target
External Assessment	Simulates an outside attacker's view (internet-facing)
Internal Assessment	Simulates an insider / assumes network access
Host-based Assessment	Checks OS-level config, patches, services on a single host
Network-based Assessment	Scans hosts/services across a network
Application-based Assessment	Targets web apps / software for logic & code flaws

Vulnerability-Management Lifecycle

1. Identify assets & create baseline
 2. Vulnerability scan
 3. Risk assessment (prioritize by severity/impact)
 4. Remediation
 5. Verification (re-scan)
 6. Monitoring / reporting
-

2. Key Standards & Databases

Standard	What it is
CVE (Common Vulnerabilities and	Dictionary of <i>publicly disclosed</i> vulnerability

Standard	What it is
Exposures)	instances, each with a unique ID (e.g., CVE-2024-xxxx)
CWE (Common Weakness Enumeration)	Catalog of <i>underlying weakness types/categories</i> (root causes) that can lead to vulnerabilities — maintained by MITRE at cwe.mitre.org
CVSS (Common Vulnerability Scoring System)	Numeric severity score (0–10) for a vulnerability: Low / Medium / High / Critical
NVD (National Vulnerability Database)	US government repository that adds CVSS scores & metadata to CVEs

CVSS Severity Ranges (v3.x): - 0.0 → None - 0.1 – 3.9 → Low - 4.0 – 6.9 → **Medium** - 7.0 – 8.9 → High - 9.0 – 10.0 → Critical

Lab reference: our OpenVAS finding scored **5.0 = Medium**.

CWE quick-reference (from this lab)

- **CWE-591** — Sensitive Data Storage in Improperly Locked Memory (data left in unlocked/swappable memory can leak to disk)
- **CWE-787** — Out-of-bounds Write — **#1 on the 2023 CWE Top 25 Most Dangerous Software Weaknesses**. Writing past a buffer's bounds → data corruption, crash, or code execution.

3. Tools Covered

OpenVAS (Greenbone Vulnerability Manager)

- Open-source, full-featured **network vulnerability scanner**.
- Workflow: create **Target** → create **Task** (bind target + scan config + scanner) → **Run** → review **Results/Report**.
- **Scan Config “Full and fast”** — broad NVT (Network Vulnerability Test) coverage, tuned for speed.
- **QoD (Quality of Detection)** — confidence % that a finding is a true positive; we filtered ≥ 70%.
- Severity dashboard shows a donut chart (by severity) and a results table (High/Medium/Low/Log/False Positive counts).
- Our scan of **10.10.1.22**: 1 Medium, 1 Low, 56 Log entries; Medium finding = “DCE/RPC and MSRPC Services Enumeration Reporting” (5.0).
 - *Why it matters*: DCE/RPC & MSRPC enumeration can leak Windows service/endpoint info useful for further attack planning.

Nikto

- Open-source **web server / web application scanner**.

- Checks for: outdated server banners, missing security headers, dangerous files/CGIs, default content, TLS misconfig.
- Security headers it commonly flags if missing:
 - X-Frame-Options (clickjacking protection)
 - Strict-Transport-Security (HSTS)
 - X-Content-Type-Options (MIME-sniffing protection)
- “Uncommon headers” = non-standard/custom headers returned by the server that may leak internal info (caching layers, proxies, backend identifiers).
- In this lab, target **certifiedhacker.com** returned an uncommon host - header containing a Base64-looking string — an example of information disclosure via a custom header.

ShellGPT

- AI-assisted CLI tool: converts a **natural-language prompt** into an executable shell command.
 - Used here to auto-generate the Nikto command line instead of typing scanner flags manually — useful for speeding up recon while still producing a standard, auditable tool command.
-

4. Lab Answer Cheat-Sheet

#	Question	Answer
1	Weakness name for CWE ID 591	Sensitive Data Storage in Improperly Locked Memory
2	Top weakness — 2023 CWE Top 25	Out-of-bounds Write (CWE-787)
3	Severity of DCE/RPC & MSRPC Services Enumeration Reporting on 10.10.1.22 (OpenVAS)	5.0 (Medium)
4	Content of uncommon host - header on certifiedhacker.com (Nikto via ShellGPT)	c2hhcmVkJmJsdWVob3N0LmNvbQ==

Module result: 4/4 — 100% — Passed (1 hr 45 min actual vs. 1 hr 20 min expected)

5. Exam-Style Takeaways

- CWE = *weakness category*; CVE = *specific instance*; CVSS = *how bad it is*. Don't mix these up.
- A CVSS 5.0 always maps to **Medium**, regardless of scanner.

- Vulnerability scanning ≠ exploitation — stop at “identify & report” unless scope explicitly allows exploitation (that’s the Penetration Testing phase of CEH, not this module).
- OpenVAS QoD filters out low-confidence/noisy findings — raising QoD reduces false positives but may hide true positives with weaker detection signatures.
- Always check *both* the presence of a header (e.g., X-Frame-Options missing) *and* the value of custom/uncommon headers (e.g., host-header) — both are separate finding classes in Nikto output.